

Multi-factor Authentication for Active Directory: Fighting MFA Fatigue Attacks

 fidelissecurity.com/threatgeek/active-directory-security/active-directory-mfa-fatigue-attacks

Srestha Roy

January 13, 2025



[Active Directory Security](#)

Listen

[Download PDF](#)

In 2024, cyberattacks aimed at MFA flaws increased by an astounding 40%. This concerning pattern indicates a sharp rise in the complexity of cyberthreats that businesses now have to deal with. Cybercriminals are now adopting psychological strategies in addition to technical ones, such as MFA fatigue attacks, which alter human behavior to obtain unauthorized access to vital systems.

This is a wake-up call, not just a number. Any business can become a target, and in today's digital environment, protecting your company from these new risks is also protecting yourself. Let's examine how you can keep ahead of these bad actors by making cybersecurity a top priority right now.

Understanding MFA Fatigue Attacks

MFA fatigue attacks, also referred to as "prompt bombing," refer to an attack in which the attackers overwhelm a user with frequent MFA push notifications. It aims to irritate or disorient users to the point of mistakenly approving a malicious login attempt.

Indeed, it is reported that this attack method works since a 1% rate of users blindly accept the first MFA notification, they receive without regard to whether it was properly triggered.

Why Multi-factor Authentication is Important to Active Directory

[Active Directory](#) regulates user access to vital resources, therefore it is one of the main targets for attackers. To secure this vital system, traditional username-password combinations are no longer sufficient. By making sure that only authorized users may access Active Directory, multi-factor authentication provides an additional degree of protection.

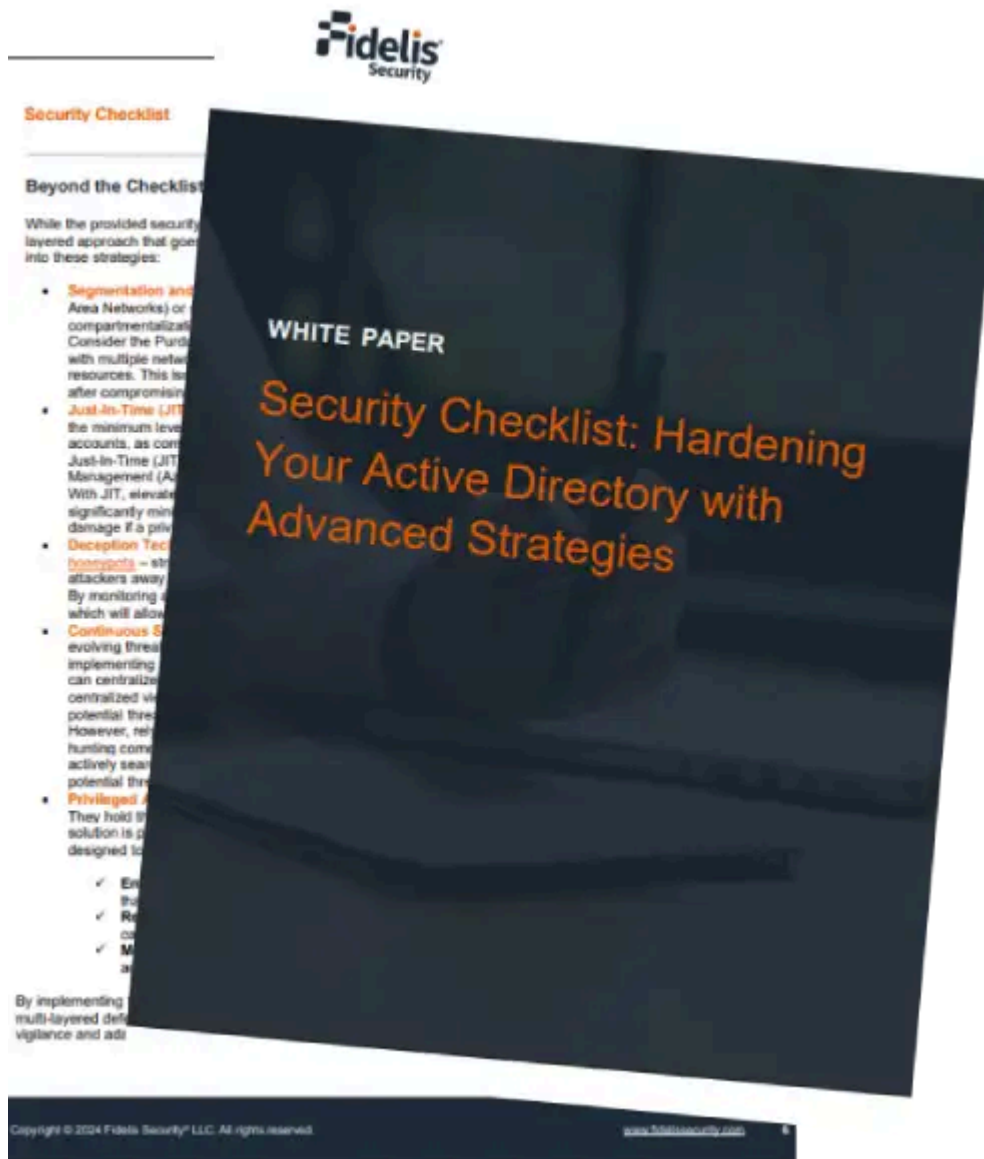
Some of the key benefits of using Active Directory two-factor authentication or MFA include:

- Reduces reliance on passwords that can be compromised.
- [Mitigates credential theft](#) and brute-force risks.
- Improves compliance with regulatory requirements.

Security Checklist: Hardening Your Active Directory with Advanced Strategies

- Statistics and Trends
- Advanced Strategies
- The Solution

[Download the Whitepaper Now!](#)



Mechanism of Multi-factor Authentication in Active Directory

Lets breakdown the process that MFA follows to [safeguard your active directory](#).

How Does MFA Work?

To understand this, MFA is an added security layer which demands that users should verify their identity through at least two factors. The following is a detailed description of how it works:

1. Authentication Factors

MFA utilizes at least two of the following factors:

Something You Know

This includes passwords, PINs or security questions' answers.

Something You Have

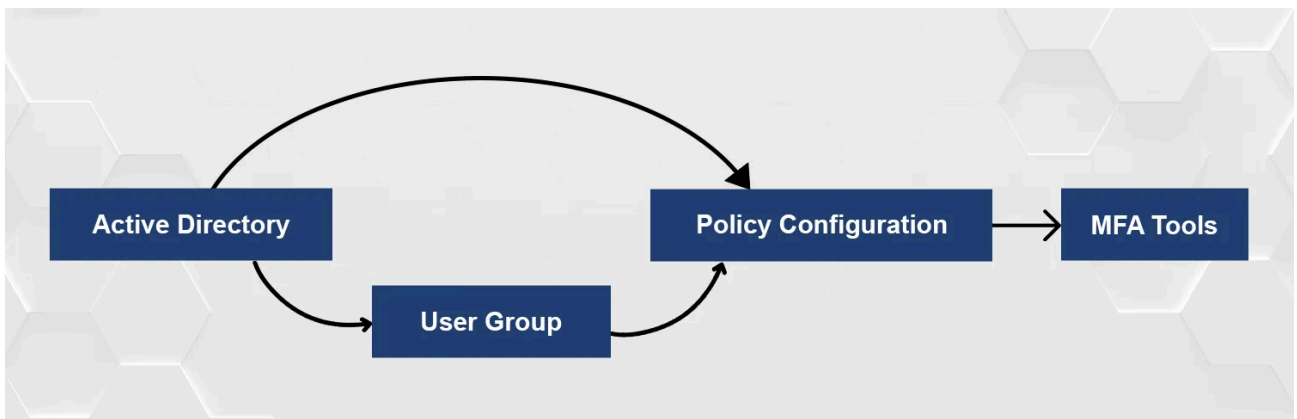
This includes hardware tokens, authenticator apps in your smartphone like Microsoft Authenticator or Google Authenticator, or smart cards.

Something You Are

This includes biometric authentication such as fingerprint, facial, or voice verification.

Example: In this case, a user of an Active Directory (AD) account may require to enter a password (something they know), and then accepts the login from an authenticator application on their phone (something they have).

2. Integration with Active Directory



Active Directory supports seamless integration with multi-factor authentication tools like [Microsoft Azure](#) MFA, providing hybrid and on-premise capabilities.

Organizations can configure policies for specific groups (e.g., admins) to require MFA for all logins.

Example: An enterprise enabling on-premise Active Directory multi-factor authentication can configure policies that mandate MFA for employees accessing financial data from external networks.

3. Real-World Application

Hybrid Workforces: Remote employees logging into Active Directory must use MFA to verify their identity, ensuring security even in distributed environments.

Critical Systems Protection: MFA can [prevent unauthorized access](#) to sensitive systems, reducing risks from phishing and credential theft.

Steps to Enable Multi-factor Authentication in Active Directory

-

Set Up an MFA Server

Deploy an on-premise multi-factor authentication server to integrate with your Active Directory.

-

Install and Configure Tools

Use multi-factor authentication tools like Microsoft Azure MFA or third-party solutions to enable MFA in your AD environment.

-

Enable MFA Policies

Define policies to ensure MFA-enabled users are prompted for additional factors during login.

-

Integrate with On-Premise Systems

For on-premise Active Directory multi-factor authentication, ensure your setup supports hybrid environments if necessary.

By following these steps, you can ensure your Windows Active Directory multi-factor authentication implementation is seamless and effective.

Choosing Between MFA Enabled vs Enforced

Feature	MFA Enabled	MFA Enforced
Definition	MFA is activated for the account but not mandatory for every login.	MFA is mandatory, and users must complete setup to log in.
Implementation	Administrators enable MFA for users, but it's optional for them to configure or use.	Users are required to set up and use MFA for all login attempts.
User Experience	Users can skip MFA setup initially or bypass it during login.	Users are prompted to complete MFA setup and cannot log in without it.
Use Case	Suitable for testing MFA or for non-critical accounts where security isn't a top concern.	Ideal for critical accounts like administrators or sensitive data access.
Risk Level	Higher risk due to potential user negligence in setting up MFA.	Lower risk as every login is verified with multiple authentication factors.
Example	An employee is notified about MFA but can opt out until it's enforced.	An admin account requires fingerprint authentication and a PIN for every access attempt.

Our Recommendation: Enforcing MFA is strongly advised for accounts with elevated privileges or sensitive data access. This ensures comprehensive protection against unauthorized access and potential breaches.

Key Strategies to Combat MFA Fatigue with Active Directory MFA

Restrict MFA Notifications

Implement tools that block repeated push notifications to prevent attackers from exploiting MFA fatigue. These tools can limit the number of notifications sent within a specific time frame, ensuring users are not overwhelmed by multiple prompts.

Time-Limited Prompts

Configure MFA to limit the number of allowed prompts per session. By setting time-based restrictions, users are only required to authenticate once within a defined period, reducing their exposure to fatigue attacks while maintaining security.

User Education

Train users to recognize suspicious activity and report excessive MFA requests. Providing examples of legitimate versus malicious prompts can empower users to identify and resist potential attacks effectively.

Conditional Access Policies

Leverage multi-factor authentication Azure Active Directory to create policies that restrict access based on location, device, or risk levels. For example, users attempting to log in from unfamiliar locations may be required to undergo additional verification steps.

How to Set Up Advanced Protection for On-Premise AD?

To strengthen security for on-premise Active Directory (AD), organizations can follow these actionable steps with real-world examples:



1. Adopt Context-Aware MFA Tools

- **Action:** Deploy context-aware tools that evaluate user behavior, device compliance, and login risk before granting access.

- **Example:** Use tools like Microsoft Azure AD Conditional Access to restrict access for users logging in from unknown devices or risky geolocations.



2. Integrate Multi-Factor Authentication Servers

- **Action:** Set up an on-premise multi-factor authentication server that works seamlessly with your AD infrastructure.
- **Example:** Implement a solution like Duo Security MFA to secure access to sensitive systems managed by your AD.



3. Enable Risk-Based Policies

- **Action:** Configure risk-based policies to enforce stricter authentication requirements for high-risk scenarios.
- **Example:** Mandate additional verification steps for administrative accounts attempting to access AD from external networks.



4. Limit Repeated Login Attempts:

- **Action:** Set up controls to block repeated login attempts from the same source to prevent MFA fatigue attacks.
- **Example:** Use rate-limiting policies in your MFA tool to block excessive push notification requests.



5. Train IT Administrators and End-Users

- **Action:** Educate both IT staff and end-users about detecting and responding to unusual MFA requests.
- **Example:** Conduct workshops to demonstrate how prompt-bombing attacks look and emphasize the importance of denying suspicious MFA notifications.

By implementing these strategies, organizations can significantly reduce the likelihood of MFA fatigue attacks and maintain robust security for on-premise AD environments.

When faced with increasingly high cyber threats, ensuring your Active Directory environments is now more than ever crucial. Using [Fidelis Security](#), implement advanced multi-factor authentication tools for protecting on-premise and cloud systems. Fortify your defenses, prevent unauthorized access, and stay ahead of the attackers.

So, what's next?

Get ready to start acting and see how Fidelis can help change your security approach today!

[Talk to an expert](#)

Frequently Ask Questions

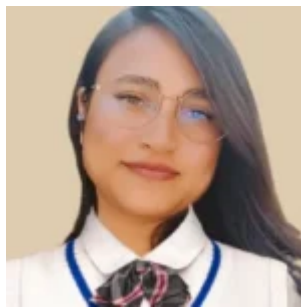
What is the AD multi-factor authentication process?

The process involves integrating an MFA solution with Active Directory, setting up authentication policies, and requiring users to verify their identity using multiple factors.

Can I use on-premise MFA for Active Directory?

What tools support Active Directory MFA?

About Author



[Srestha Roy](#)

Srestha is a cybersecurity expert and passionate writer with a keen eye for detail and a knack for simplifying intricate concepts. She crafts engaging content and her ability to bridge the gap between technical expertise and accessible language makes her a valuable asset in the cybersecurity community. Srestha's dedication to staying informed about the latest trends and innovations ensures that her writing is always current and relevant.

One Platform for All Adversaries

See Fidelis in action. Learn how our fast and scalable platforms provide full visibility, deep insights, and rapid response to help security teams across the World protect, detect, respond, and neutralize advanced cyber adversaries.

[Get a Demo](#)